

14

Server Side Request Forgery (SSRF)



Server Side Request Forgery (SSRF)



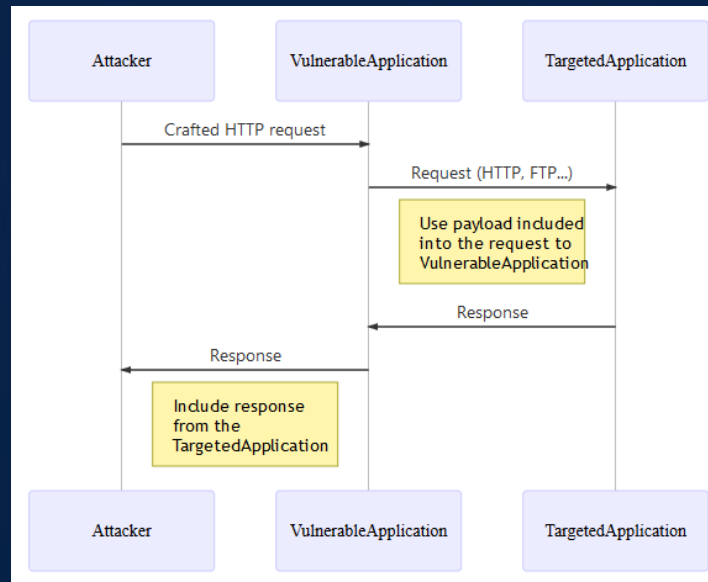
Kullanıcı kontrolünde olan girdiler üzerinden sunucu tarafı istekler yapıldığı durumlarda görülmektedir.



Harici kaynaklara olan erişim talepleri



file://, phar://, gopher://, data://, dict://



Server Side Request Forgery (SSRF)

PDF Render & Bypass Teknikleri

PDF Rendering

```
<script>
function resp () {
document.write(this.responseText);
}

var xmlreq = new XMLHttpRequest();
xmlreq.addEventListener("load", resp);
xmlreq.open("GET", "file://etc/passwd");
xmlreq.send();
</script>
```

```
<iframe src="
http://169.254.169.254/latest/meta-data/">
```

Yönlendirme ile Blacklist'in atlatılması

```
<?php header("location:
http://169.254.169.254/latest/meta-data/");
?>
```

<https://hackerone.com/reports/508459>

Hex/octal IP

```
http://[::]:80/
http://2130706433/ = http://127.0.0.1
0x7f.0x0.0x0.0x1
0177.0.0.01
```



Uygulama

SSRF

Örnek-1

Örnek-2



Server Side Request Forgery (SSRF)

Önlem



Beyaz liste yaklaşımı ile girdi denetimi (String, IP, Domain name, URL)



İzin verilen adresler ve protokoller için **beyaz liste** yaklaşımı uygulanmalıdır.



Hem uygulama katmanında hem de Network katmanında güvenlik önlemleri alınmalıdır.



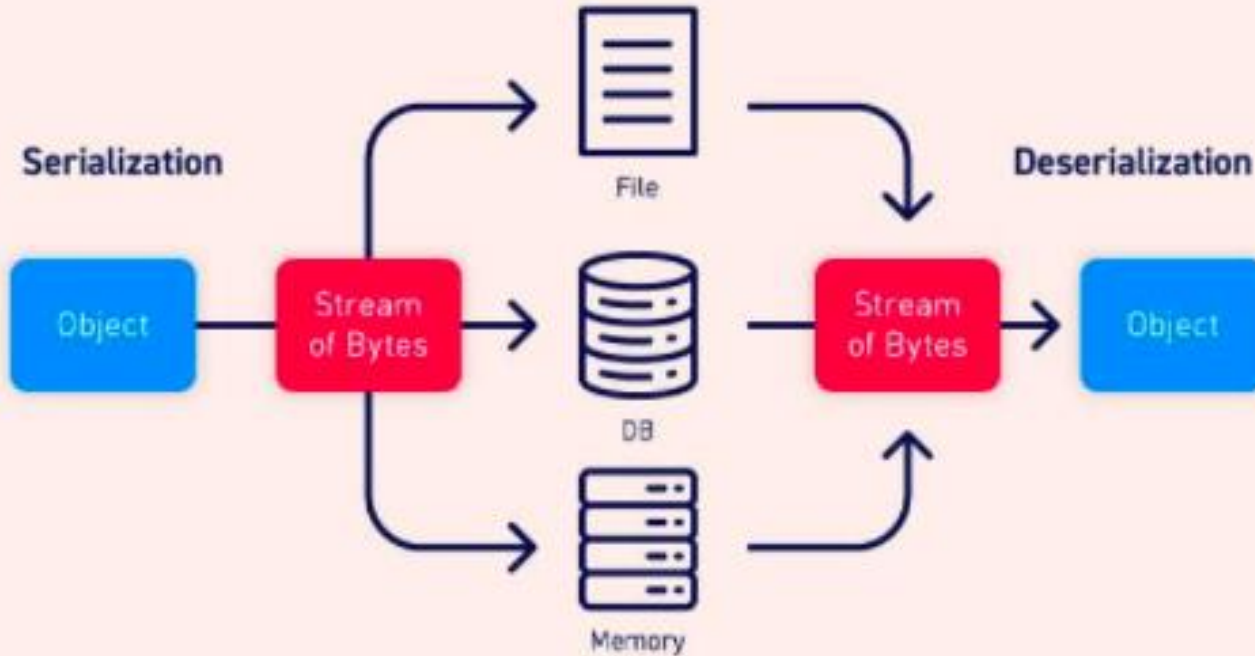
Web uygulama üzerinde, yönlendirmenin takip edilmesi desteği devre dışı bırakılmalıdır.

15

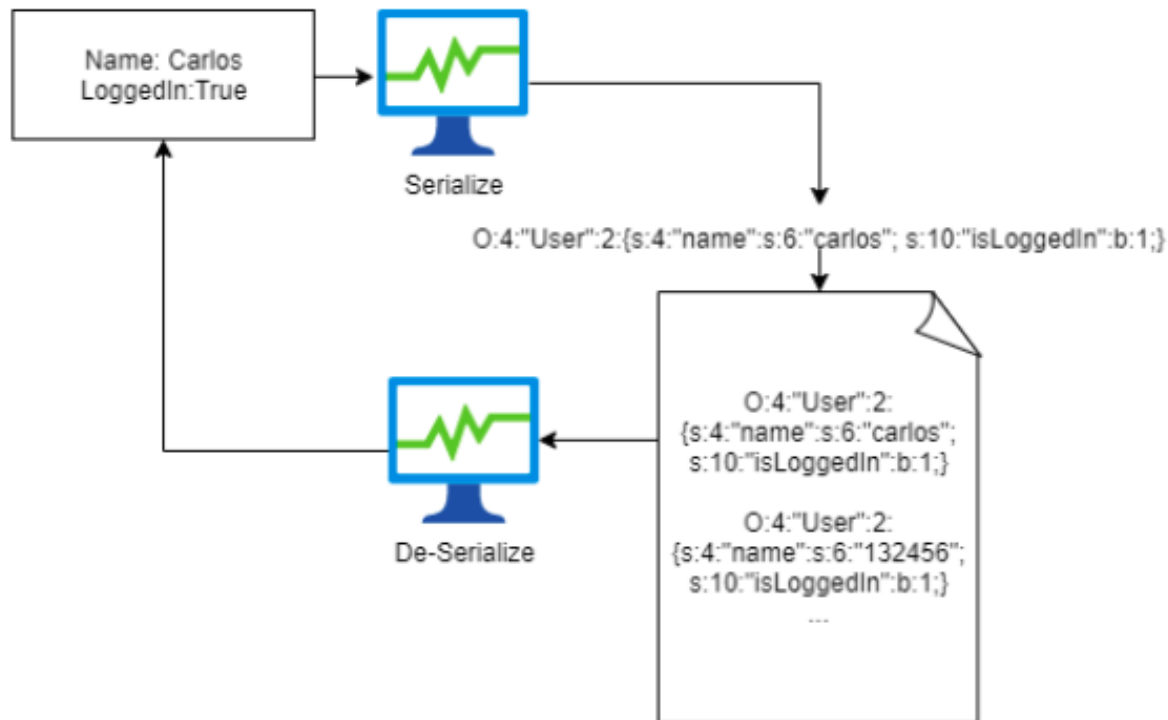
Insecure Deserialization



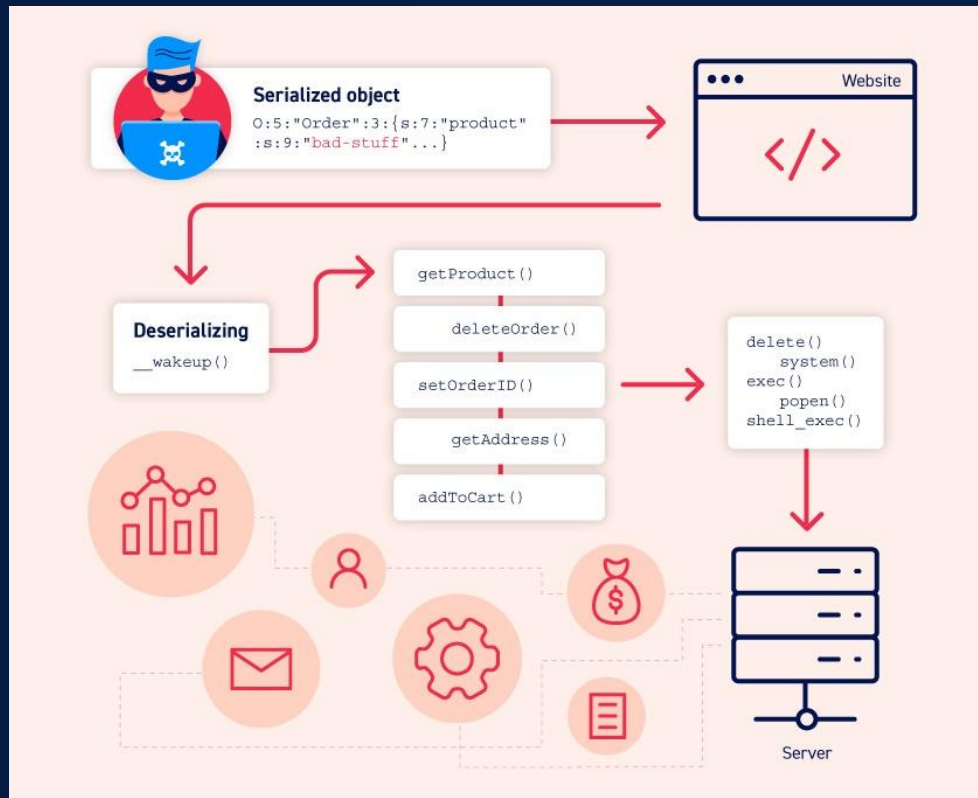
Serialization - Deserialization



Serialization - Deserialization



Insecure Deserialization



Insecure Deserialization

```
class User {  
  
    private String userID;  
    private String pass;  
  
    public User(String userID, String pass){  
        this.userID = userID;  
        this.pass = pass;  
    }  
}
```

```
//Kullanıcı nesnesini oluşturalım  
User user = new User("anil", "s3cr3tP4$$w0rd!");  
String filename = "user.txt";  
  
//Serialization  
//Nesne dosyaya yazılıyor  
try (FileOutputStream file = new FileOutputStream(filename);  
    ObjectOutputStream out = new ObjectOutputStream(file)){  
    //Nesne serileştiriliyor  
    out.writeObject(user);  
  
} catch (IOException ex){  
    ex.printStackTrace();  
}
```

```
//Deserialization  
//Nesne dosyadan okunuyor  
//Saldırgan tarafından içeriği değiştirilmiş bir dosya ile zararlı aktivite oluşturulabilir  
try (FileInputStream file = new FileInputStream(filename);  
    ObjectInputStream in = new ObjectInputStream(file)){  
    //Nesne seriden çıkarılıyor  
    User userData = (User)in.readObject();  
    //User sınıfı ile yapılacak işlemler yapılabilir  
} catch (IOException ex){  
    ex.printStackTrace();  
} catch (ClassNotFoundException ex){  
    ex.printStackTrace();  
}
```

Insecure Deserialization Lab



Örnek

Korunma Yöntemleri



Dilden bağımsız formatlar kullanımı



Bütünlük kontrolleri



Girdi denetimleri



Düşük yetkili ortam kullanımı

16

Open Redirection



Open Redirection



Güvenilmeyen girdi olarak sağlanan bir URL üzerinden yeniden yönlendirmeye izin veren uygulamalarda karşımıza çıkar.



Bir saldırgan, güvenilmeyen URL girişini **kötü amaçlı** bir siteye yönlendirerek kullanıcı kimlik bilgilerini çalabilir.

```
response.sendRedirect(request.getParameter("url"));
```

```
http://example.com/example.php?url=http://malicious.example.com
```

Open Redirection



Mümkünse kullanıcı girdisine bağımlı olarak yönlendirme işlemlerinden kaçınılmalıdır.



Kullanıcı girdisinden kaçınılamıyorsa, sağlanan değerin geçerli, uygulama için uygun ve kullanıcı için yetkilendirilmiş olduğundan emin olunmalıdır.



Uygulamada yönlendirme yapılan noktalarda beyaz liste yöntemi ile doğrulama yapılarak sadece izin verilen adreslere yönlendirme sağlanmalıdır.



Yönlendirme işlemlerinde, kullanıcılara sitenizden çıkacaklarını bildiren, hedefin adresin gösterildiği bir bilgilendirme gösterilmeli ve onaylamak için bağlantıyı tıklamaları sağlanmalıdır.

17

Directory Traversal



Directory Traversal



Kullanıcıdan alınan girdiler üzerinden herhangi bir kontrole tabii tutulmadan, dinamik olarak dosyalara/dizinlere erişim sağlanması durumunda Directory Traversal zafiyeti ortaya çıkar.



Sunucu üzerindeki dosyalara/dizinlere yetkisiz erişim sağlanması

```
https://example.com/get-files.jsp?file=report.pdf
```

Directory Traversal

```
<?php
$template = 'red.php';
if (isset($_COOKIE['TEMPLATE'])) {
    $template = $_COOKIE['TEMPLATE'];
}
include "/home/users/phpguru/templates/" . $template;
```

```
GET /vulnerable.php HTTP/1.0
Cookie: TEMPLATE=../../../../../../../../../../../../etc/passwd
```



Uygulama

Directory Traversal

Örnek-1

Örnek-2

Örnek-3



Directory Traversal



İzin verilen dosya isimleri **beyaz listeye** eklenerek, kontrol edilmelidir.



../ gibi ifadelerin kara listeye eklenmesi, çeşitli yöntemlerle atlatılabilir!



Uygulama kullanıcısı en az yetki prensibini ile çalışmalıdır.



Dosya adı için canonical dosya yoluna bakılmalı ve temel dizin ile başlayıp, başlamadığı kontrol edilmelidir. (Örnek olarak javada getCanonicalPath() fonksiyonu)

```
File file = new File(BASE_DIRECTORY, userInput);
if (file.getCanonicalPath().startsWith(BASE_DIRECTORY)) {
    // process file
}
```

18

Güvensiz Yapılandırma Kaynaklı Zafiyetler

Zafiyetli Bileşen Kullanımı
Bilgi Ifşaları
Dizin Listeleme
Debug Mod Kullanımı
Uygunsuz Varlık Yönetimi
Rate Limiting
Client Side Filtering

Soru



File | /Users/anilbas/Desktop/siberkamp.html

Turkcell Siberkamp

Bu sayfada girdi yok

Zafiyetli Bileşen Kullanımı



Uygulamalarda çoğunlukla kütüphaneler veya bazı ürünler kullanılır.



Eğer kullanılan bileşenlerde bilinen güvenlik zafiyetleri varsa, bu bileşen üzerinden hedef uygulama da risk altında kalacaktır.

Zafiyetli Bileşen Kullanımı

Önlem



Uygulamada kullanılan bileşenlerin bilinen bir güvenlik açığı olup olmadığı kontrol edilmelidir.



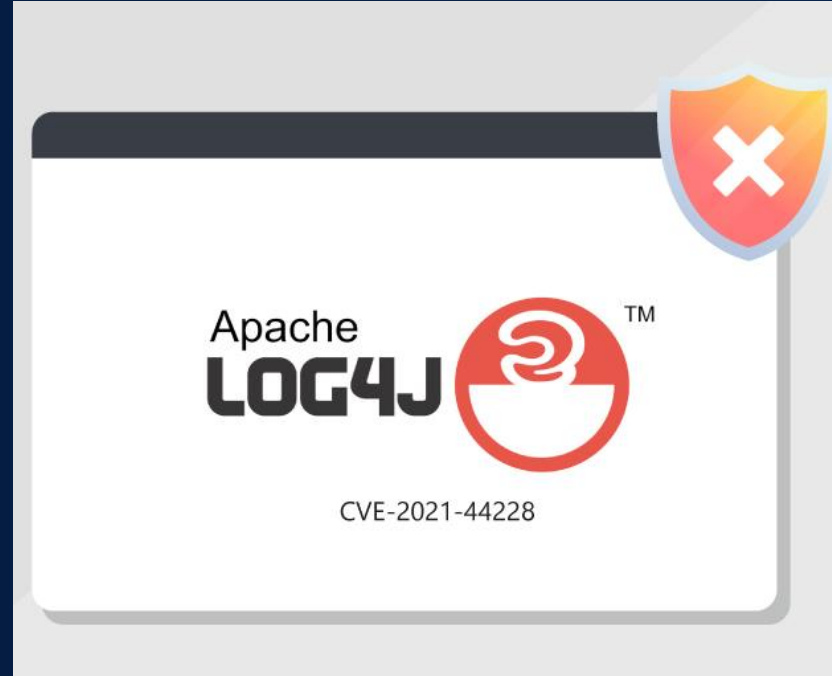
Uygulamalarda kullanılan bağımlılıkların envanteri tutulmalı ve belirli aralıklarla kontrol edilmelidir.



Uygulamalarımızda kullanılan bileşenlerin güncel tutulması / güncel sürümlerin kullanılması gerekmektedir.

Zafiyetli Bileşen Kullanımı

Apache Log4J Zafiyeti



Uygunsuz Varlık Yönetimi



Saldırganlar, tespit ettikleri test ortamları ve API eski sürümleri üzerinden saldırılar gerçekleştirebilir.



Bu ortamların, PROD ortamlar gibi iyi korunmadığı bilinen bir gerçektir.

Uygunsuz Varlık Yönetimi

Önlem



Envanter sürekli güncellenmeli ve takip edilmelidir.



API'lerin eski sürümlerinin kullanımdan kaldırılması önerilmektedir.



Yalnızca geçerli PROD ortam için değil, kullanımda olan tüm sürümler için harici koruma önlemleri uygulanmalıdır.



Test ortamlarına erişimin kısıtlanması ve bu ortamların ayrılması önerilir.



API dokümantasyonlarının sadece yetkili kişiler tarafından erişilmesi sağlanmalıdır.

Rate Limiting



 API çağrıları yapılırken, istek sınırlaması olmaması sunucunun kaynaklarını gereksiz yere tüketerek, servis dışı kalmasına sebep olabilir.

 Mail gönderme, iletişim formu, OTP gönderim servisleri, büyük cevaplar dönebilecek servislerde bu durum değişik etkilere sebep olabilir.

Rate Limiting

Önlem



Yapılan istekler için boyut sınırlaması belirlenerek, sunucu tarafında kontrol edilmelidir.



Cevapta döndürülecek kayıt sayısı kontrol edilmelidir.



Belirli bir süre içerisinde API'nin ne sıklıkla çağırılacağına sınırlama getirilmelidir.

Client-side Filtering



Genellikle, sunucudan toplu bir şekilde veriyi döndürüp, kullanıcı tarafında filtreleme yapılması ve sadece istenilen bilgilerin kullanıcıya gösterilmesi ile risk oluşturur.

599-999-99-99



5XX-XXX-XX-XX

Client-side Filtering

Önlem



Kullanıcı tarafında yapılan filtrelemelere asla güvenilmemelidir.



Uygulamadan veri dönen noktalar incelenmeli, gereksinimi belirleyerek en az miktarda veri döndürülmelidir.

Bilgi İfşaları & Hata Ayıklama Modu



Sistem hakkında bilgi açığa çıkartan durumlar; Server versiyonu ve teknoloji ifşaları, detaylı hata mesajları vs.



Hata ayıklama modu geliştirme aşamasında geliştiricilere kolaylık sağlar.



Üretim ortamında hata ayıklama modunun açık bırakılması saldırganlara uygulama hakkında hassas veri ifşaları sağlayabilir.

Server Error in '/' Application.

Failed to generate a user instance of SQL Server due to failure in retrieving the user's local application data path. Please make sure the user has a local user profile on the computer. The connection will be closed.

Description: An unhandled exception occurred during the execution of the current web request. Please review the stack trace for more information about the error and where it originated in the code.

Exception Details: System.Data.SqlClient.SqlException: Failed to generate a user instance of SQL Server due to failure in retrieving the user's local application data path. Please make sure the user has a local user profile on the computer. The connection will be closed.

Source Error:

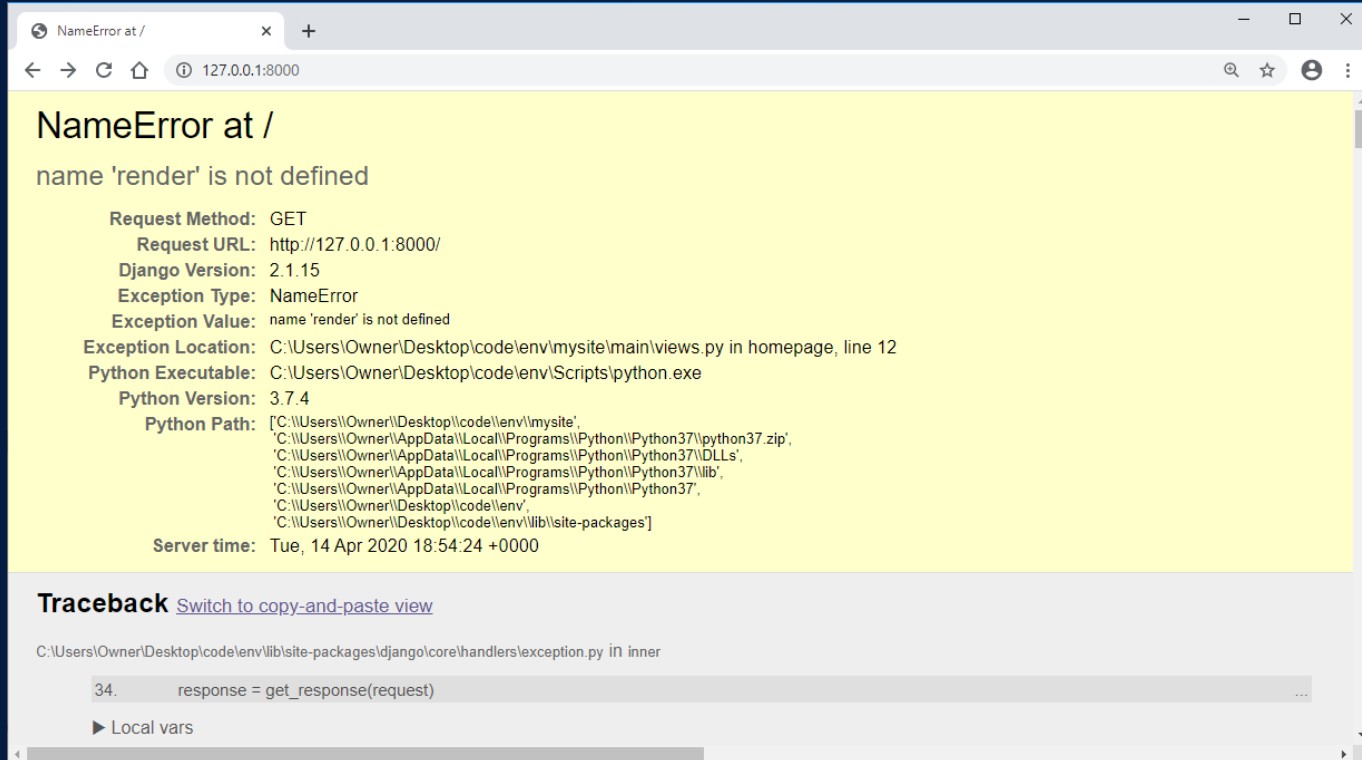
```
Line 139:                                     dbConnection conn = provider.CreateConnection();
Line 140:                                     conn.ConnectionString = connectionString;
Line 141:                                     conn.Open();
Line 142:
Line 143:                                     s_connectionPool[i] = conn;
```

Source File: c:\inetpub\wwwroot\BuySpys\SwissApp_Code\Configuration.cs Line: 141

Stack Trace:

```
[SqlException (0x80131904): Failed to generate a user instance of SQL Server due to failure in retrieving
System.Data.SqlClient.SqlInternalConnection.OnError(SqlException exception, Boolean breakConnection) +4
System.Data.SqlClient.TdsParser.ThrowExceptionAndWarning(TdsParserStateObject stateObj) +194
System.Data.SqlClient.TdsParser.Run(RunBehavior runBehavior, SqlCommand cmdHandler, SqlDataReader data
System.Data.SqlClient.SqlInternalConnectionTds.CompleteLogin(Boolean enlistOK) +35
System.Data.SqlClient.SqlInternalConnectionTds.AttemptOneLogin(ServerInfo serverInfo, String newPassword
System.Data.SqlClient.SqlInternalConnectionTds.LoginNoFailover(String host, String newPassword, Boolean
System.Data.SqlClient.SqlInternalConnectionTds.OpenLoginEnlist(SqlConnection owningObject, SqlConnection
System.Data.SqlClient.SqlInternalConnectionTds..ctor(DbConnectionPoolIdentity identity, SqlConnectionSt
System.Data.SqlClient.SqlCommandInitServer.CreateConnectionTdsCommandInitServerOptions, Object poolId
```

Bilgi İfşaları & Hata Ayıklama Modu



NameError at /

name 'render' is not defined

Request Method: GET
Request URL: http://127.0.0.1:8000/
Django Version: 2.1.15
Exception Type: NameError
Exception Value: name 'render' is not defined
Exception Location: C:\Users\Owner\Desktop\code\env\mysite\main\views.py in homepage, line 12
Python Executable: C:\Users\Owner\Desktop\code\env\Scripts\python.exe
Python Version: 3.7.4
Python Path: [C:\\Users\\Owner\\Desktop\\code\\env\\mysite',
C:\\Users\\Owner\\AppData\\Local\\Programs\\Python\\Python37\\python37.zip',
C:\\Users\\Owner\\AppData\\Local\\Programs\\Python\\Python37\\DLLs',
C:\\Users\\Owner\\AppData\\Local\\Programs\\Python\\Python37\\lib',
C:\\Users\\Owner\\AppData\\Local\\Programs\\Python\\Python37',
C:\\Users\\Owner\\Desktop\\code\\env',
C:\\Users\\Owner\\Desktop\\code\\env\\lib\\site-packages]
Server time: Tue, 14 Apr 2020 18:54:24 +0000

Traceback [Switch to copy-and-paste view](#)

C:\Users\Owner\Desktop\code\env\lib\site-packages\django\core\handlers\exception.py in inner

```
34.     response = get_response(request)
```

► Local vars

Dizin Listeleme



Web sunucuları, bir index sayfası bulunmayan dizinlerin içeriğini listeler.



Bu durum, webroot klasörü altında yer alan gizli ve hassas dosyaların açığa çıkmasına sebep olacaktır.

Index of /content

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 license.txt	2019-01-02 02:07	19K	
 readme.html	2019-04-09 04:29	7.3K	
 wp-activate.php	2019-01-12 12:11	6.8K	
 wp-config-sample.php	2019-01-08 10:00	2.8K	
 wp-config.php	2017-12-07 17:00	3.1K	
 wp-content/	2012-01-08 22:31	-	
 wp-includes/	2019-05-21 23:54	-	
 xmlrpc.php	2018-08-17 07:21	3.0K	

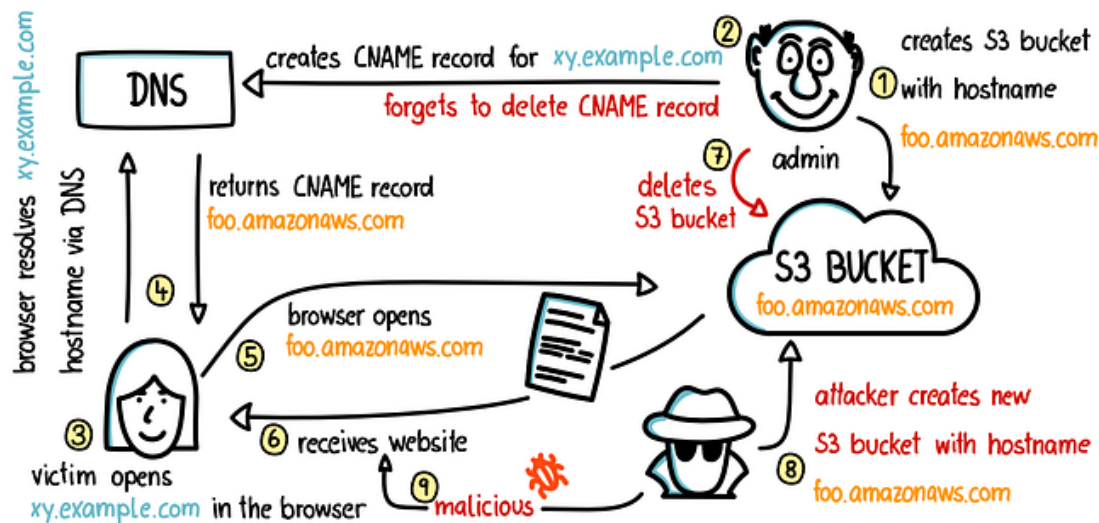
19

Subdomain Takeover



Subdomain Takeover

SUBDOMAIN TAKEOVER



security-flashcards.com

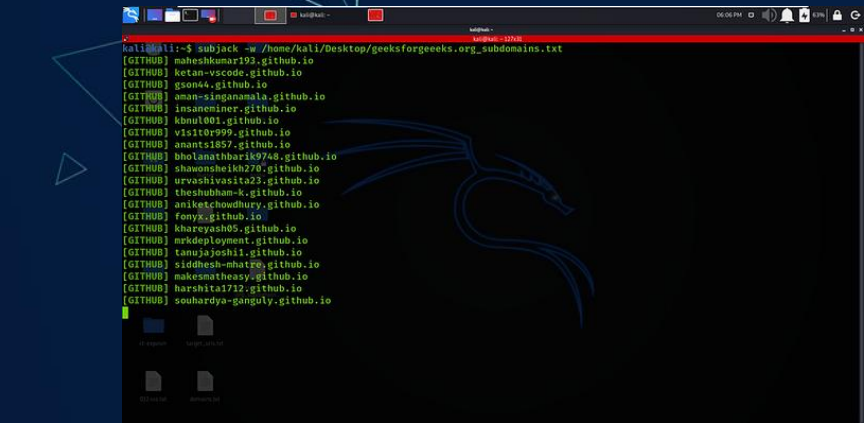


Subdomainlerin keş

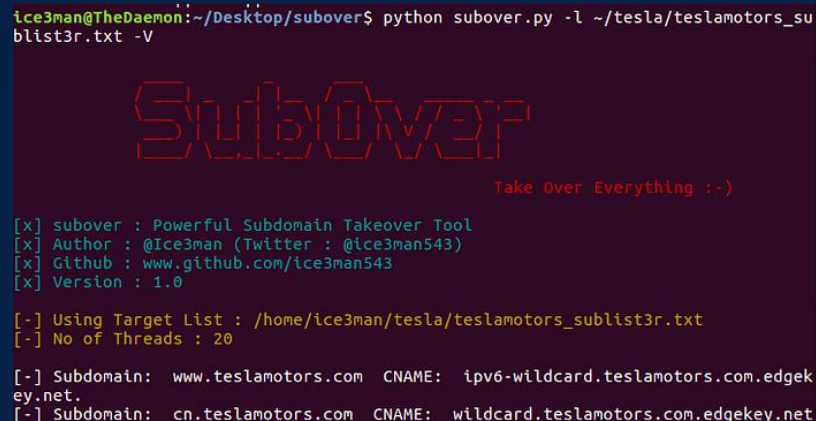
-

[illegible]

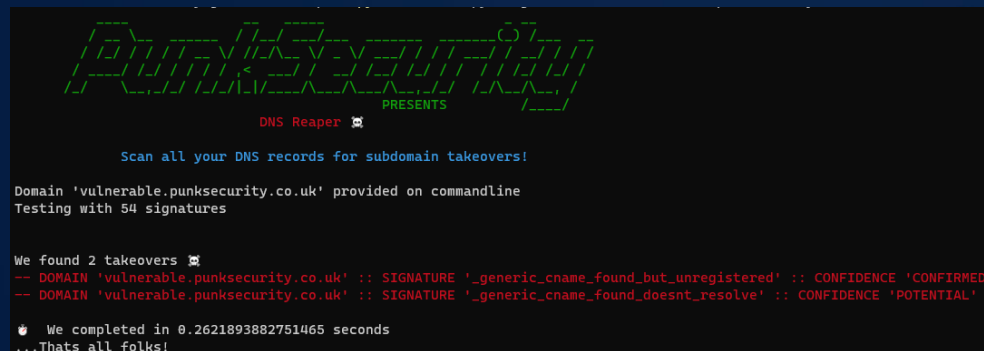
Otomatize Kontrol Araçları



SubJack



SubOver



dnsReaper

Korunma Yöntemleri



Düzenli subdomain envanter kontrolü



DNS izleme ve temizleme

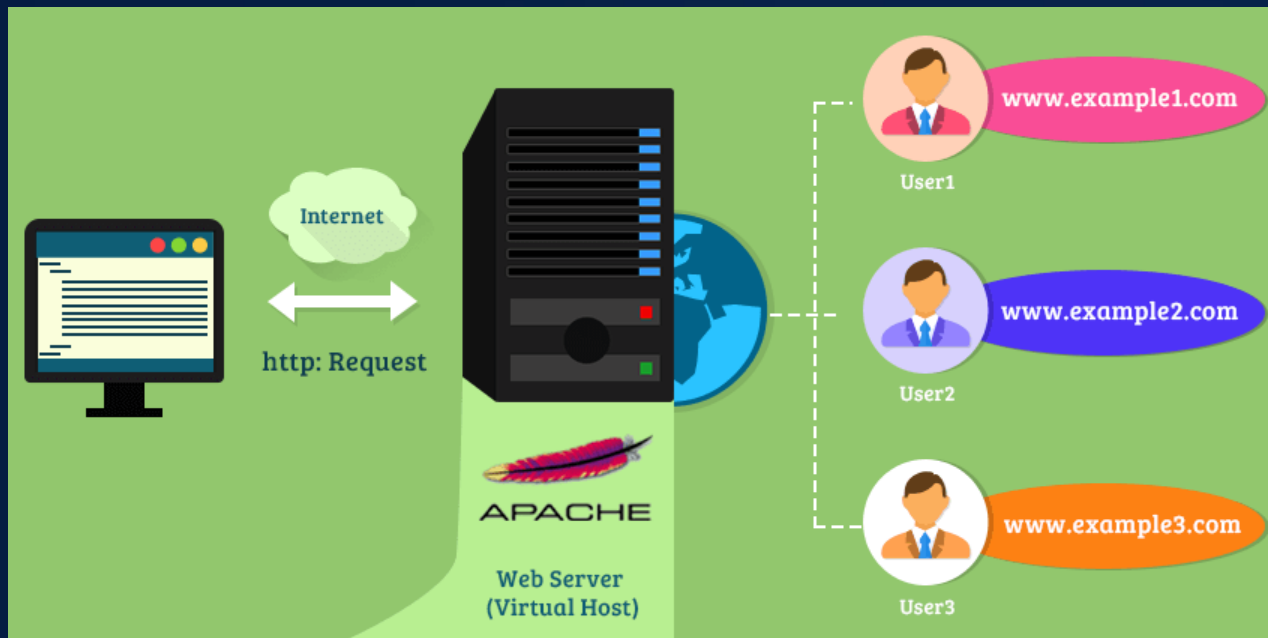


20

Host Header Injection

Virtual Host, HTTP Host Header
Lab çözümü
Korunma yöntemleri

Virtual Host



Host Header

Host başlığı, HTTP isteği içerisinde talep edilen kaynağın host ve port bilgisini belirtir.

Request

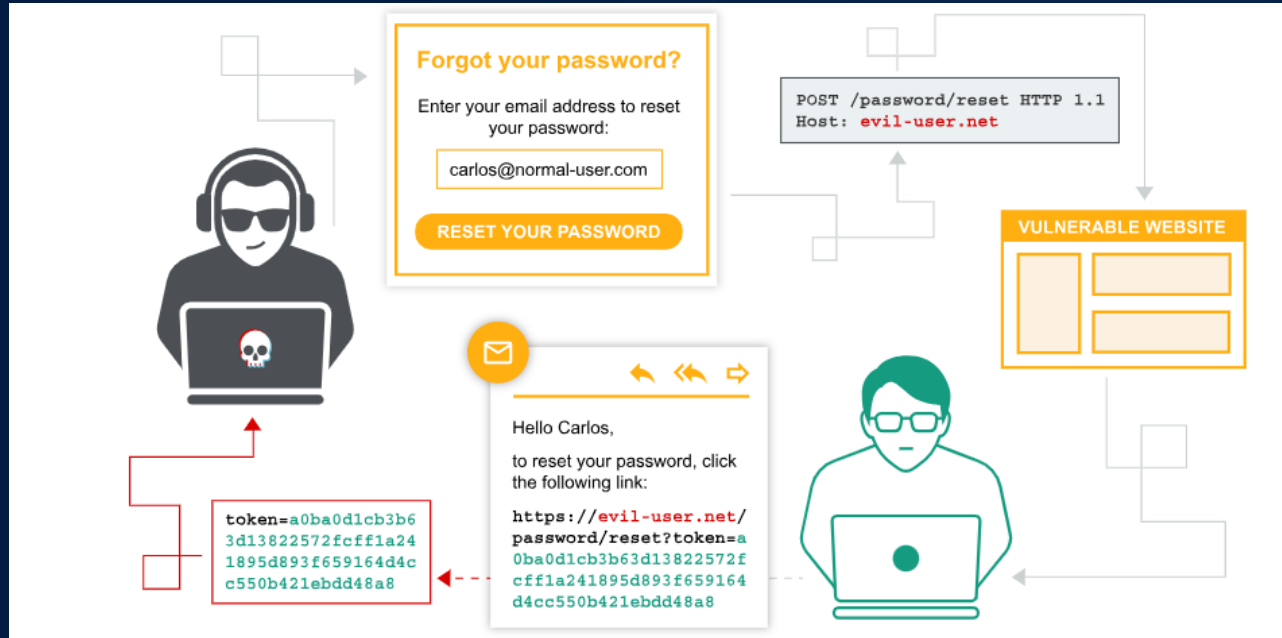
Pretty Raw Hex



```
1 GET / HTTP/2
2 Host: www.google.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:129.0)
  Gecko/20100101 Firefox/129.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/
  webp,image/png,image/svg+xml,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Upgrade-Insecure-Requests: 1
8 Sec-Fetch-Dest: document
9 Sec-Fetch-Mode: navigate
10 Sec-Fetch-Site: none
11 Sec-Fetch-User: ?1
12 Priority: u=0, i
13 Te: trailers
```

Host Header Injection

HTTP Host başlığı = Kullanıcı Girdisi



Host Header Injection Lab



WEB SECURITY
ACADEMY

Örnek-1

Korunma Yöntemleri

- Absolute URL'ler yerine Relative URL'ler kullanılmalıdır.
 - **Absolute URL:** `<a href = "https://www.example.com/src/sample.html">`
 - **Relative URL:** `<a href = "/src/sample.html">`
- Kullanıcıdan gelen host başlık bilgisine güvenilmemelidir. Örneğin, host bilgisi sunucu tarafında bir konfigürasyon dosyasına yazılabilir ve ihtiyaç duyulması durumunda buradan okunabilir.
- Host başlık bilgisi **beyaz liste yaklaşımı** ile kontrol edilmelidir.
- Host başlık bilgisinin kontrol edildiği durumlarda saldırganlar, load blancer veya reverse proxy altyapılarında kullanılan "**X-Forwarded-Host**" gibi başlık bilgilerini isteğe dahil ederek bu durumu atlatmaya çalışabilir. Bu başlık bilgileri, siz özel olarak belirtmeseniz bile varsayılan olarak desteklenebilir. Bu sebeple, host başlık bilgisinin ezilmesine olanak tanıyan bu başlık bilgilerinin desteklenmediği kontrol edilmelidir.



22

BugBounty (Ödül Avcılığı)

Ödül Avcılığı Programları ile Güvenlik Açıklarının Keşfi

BugBounty

Güvenlik araştırmacılarının tespit ettikleri açıklıklar karşılığında ödül kazandıkları programdır.

Araştırmacılar, sistemlerdeki güvenlik açıklarını tespit edip bildirdiklerinde;

- Para ödülleri,
- Puan,
- Onur Listesi (Hall of Fame)
- Hediye kutuları vb. ödüller kazanırlar.

Hem şirketler hem de araştırmacılar için kazan-kazan ilişkisi

- Public
- Private
- VDP



BugBounty - Faydaları

Şirketler için

- Topluluğun gücünden yararlanarak güvenlik açıklarının hızlıca bulunması
- Güvenlik maliyetlerinin azalması

Araştırmacılar için

- Kariyer fırsatları ve gelir elde etme
- Teknik gelişim imkanı

BugBounty - Platformlar

The logo for Hackerone, featuring the word "hackerone" in a lowercase, black, sans-serif font. The letter "h" is stylized with a vertical line that extends upwards and then curves back down to the left, forming a shape reminiscent of a network node or a stylized 'h'.

Hackerone

The logo for Bugcrowd, featuring the word "bugcrowd" in a lowercase, orange, sans-serif font. The letter "b" is stylized with a vertical line that extends upwards and then curves back down to the left, forming a shape reminiscent of a network node or a stylized 'b'.

Bugcrowd

The logo for Intigriti, featuring a stylized icon of a shield with a cross inside, followed by the word "INTIGRITI" in a bold, uppercase, dark blue, sans-serif font.

Intigriti

The logo for YesWeHack, featuring a stylized icon of a shield with a cross inside, followed by the word "YesWeHack" in a bold, uppercase, black, sans-serif font. The word "Yes" is in black, "We" is in red, and "Hack" is in black.

YesWeHack

BugBounty - Kimler İçin?



Globalde BugBounty

NEWS 30 OCT 2023

HackerOne Exceeds \$300m in Bug Bounty Payments



Phil Muncaster

UK / EMEA News Reporter, Infosecurity Magazine

Email Phil Follow @philmuncaster

Ethical hackers using the HackerOne bug bounty program have earned over \$300m since its inception over a decade ago, according to a new report.

Microsoft Bounty Programs

July 01, 2022 to June 30, 2023

\$13.8M
in bounty rewards



17
Bounty programs



1,180
Eligible vulnerability
reports



345
Researchers awarded



\$200K
Biggest reward

BugBounty - Süreç

Public/private/
VDP
programının
açılması

Güvenlik
araştırmacıların
davet edilmesi/
katılımı

Zafiyetlerin
tespiti ve
raporlanması

Triyaj
süreci

Zafiyete
yönelik
aksiyon
süreci

Doğrulama
testi

Ödüllerin
dağıtılması

BugBounty - Program Kapsamı



Programda yer alan uygulama/uygulamaların kapsamlarına dikkat edilmesi önemlidir.



Programlarda;

- Kapsam dışı bırakılmış URL/Uygulama ve
- Kapsam dışı bırakılmış güvenlik bulgusu olabilir.



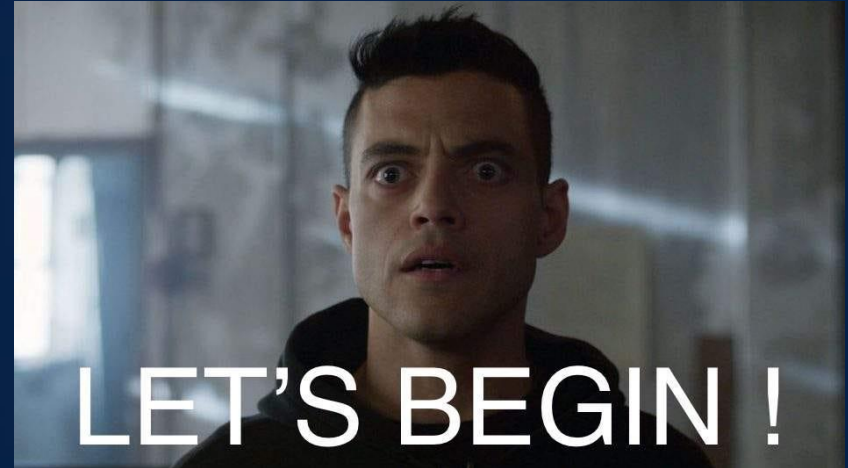
BugBounty - Zorluklar



BugBounty - Hedef Seçme

Program Seçimi

- İlgilendiğin alanlara yönelik program seç
- Programın yaşı
- Firmanın kapsamı
- Ödül miktarı
- Programın duyarlılığı



BugBounty - Etkili Rapor Yazma



Etkili rapor yazımı BugBounty'de kilit nokta!



Raporladığınız bulgunun bir güvenlik zafiyeti olduğuna ikna etmeniz ve neye sebep olacağını net bir şekilde belirtmeniz gerekir.



Bir güvenlik açığı bildirmeden önce aşağıdaki kriterlere uyum sağlaması gereklidir.

- Bu güvenlik zafiyeti kapsamdaki varlıklarda mı?
- Tespit ettiğim güvenlik zafiyeti geçerli görülen zafiyetler arasında yer alıyor mu?
- Bu tespitin gerçekten bir güvenlik etkisi var mı?



BugBounty - Etkili Rapor Yazma



Etkili bir zafiyet raporu yasmak için aşağıdaki ipuçları fayda sağlayacaktır.

- Netlik raporun anahtarıdır. Rapor, okuyan herkesin anlayabileceği bir yazım dili ile net şekilde hazırlanmalıdır.
- Gerekli kısımlar ayrıntılı bir şekilde açıklanmalı ve belirsizliğe yer bırakılmamalıdır.
- Görselleri kullanın. Mümkün olduğunca ekran görüntüsü, video, diyagram vb. Araçlarla raporunuzu destekleyin. Görseller raporun anlaşılabilirliğini önemli derecede arttıracaktır.



BugBounty - Etkili Rapor Yazma

Örnek bir raporun bölümleri

Description (Açıklama)

Tespit edilen güvenlik açığına ilişkin bilgi verilir. Hangi varlıkta, hangi CWE, neye neden oluyor gibi bilgiler verilerek okuyucuya genel çerçeveyi çizer.

Proof of Concept (PoC) / Exploitation

Zafiyetin varlığını kanıtlar biçimde bir belge (sömürü kodu, ekran görüntüsü vb.) sağlanır. Bu bölümde zafiyetin sömürü adımlarından da bahsedilebilir.

Impact (Etki)

Zafiyetin potansiyel etkileri net bir şekilde açıklanır. Etki değerlendirme kriterleri ile desteklenir.

Remediation (İyileştirme)

Zafiyetin kök nedeni açıklanır ve bu zafiyetin çözümü için alınması gereken geçici ve kalıcı yönlü aksiyonları listelenir.

References (Referanslar)

Tespit edilen zafiyete ilişkin daha fazla detay vermek için kullanılır. İlgili zafiyetin CWE dokümantasyonu, zafiyete yönelik daha önceden yayınlanmış teknik inceleme yazıları vb. dokümanlar eklenebilir.

CVSS



Common Vulnerability Scoring System (CVSS), bildirilen güvenlik zafiyetlerinin standartlaştırılmasında kullanılan bir skorelama sistemidir.

BASIC METRIC GROUP

Exploitability Metrics

Attack Vector

Attack Complexity

Privileges Required

User Interaction

Scope

Impact Metrics

Compatibility Impact

Integrity Impact

Availability Impact

Scope

CVSS v3.0 Ratings

Low

0.1-3.9

Medium

4.0-6.9

High

7.0-8.9

Critical

9.0-10.0

<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

CWE



Common Weakness Enumeration (CWE), yaygın yazılım ve donanım zayıflıklarının listesidir.



Herhangi bir zafiyet bildirilirken, bildirilen zafiyetin türünü belirtmek için kullanılır.



Common Weakness Enumeration

A Community-Developed List of Software & Hardware Weakness Types

<https://cwe.mitre.org>

23

Recon



Whois Sorgulari

```
(pentest@kali)-[~/go/bin]
$ whois google.com
Domain Name: GOOGLE.COM
Registry Domain ID: 2138514_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2019-09-09T15:39:04Z
Creation Date: 1997-09-15T04:00:00Z
Registry Expiry Date: 2028-09-14T04:00:00Z
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2086851750
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
Name Server: NS1.GOOGLE.COM
Name Server: NS2.GOOGLE.COM
Name Server: NS3.GOOGLE.COM
Name Server: NS4.GOOGLE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2024-08-18T21:01:25Z <<<
```



<https://viewdns.info/>

DNS

```
(pentest@kali) - [~/go/bin]  
$ echo "google.com" | ./dnsx -recon
```



projectdiscovery.io

```
[INF] Current dnsx version 1.2.1 (latest)  
google.com [A] [142.250.184.238]  
google.com [AAAA] [2a00:1450:4017:80f::200e]  
google.com [MX] [smtp.google.com]  
google.com [NS] [ns4.google.com]  
google.com [NS] [ns2.google.com]  
google.com [NS] [ns3.google.com]  
google.com [NS] [ns1.google.com]  
google.com [SOA] [ns1.google.com]  
google.com [SOA] [dns-admin.google.com]  
google.com [TXT] [v=spf1 include:spf.google.com ~all]  
google.com [TXT] [apple-domain-verification=30afibcvsudv2plx]  
google.com [TXT] [google-site-verification=tv9-dbe4r80x4v0m4u_bd_j9cpojm0nikft0jagjmsq]  
google.com [TXT] [onetrust-domain-verification=de01ed21f2fa4d8781cbc3ffb89cf4ef]  
google.com [TXT] [globalsign-smime-dv=cdyx+xfhuw2wml6/gb8+59bsh31kzur6c1l2bpvqxk8=]  
google.com [TXT] [docusign=05958488-4752-4ef2-95eb-aa7ba8a3bd0e]  
google.com [TXT] [docusign=1b0a6754-49b1-4db5-8540-d2c12664b289]  
google.com [TXT] [google-site-verification=4ibfugb-wxlq_s7vsxvomstvamuoXBivazpr5iz87d0]  
google.com [TXT] [cisco-ci.domain-verification=479146de172eb01ddee38b1a455ab9e8bb51542ddd7f1fa298557dfa7b22d963]  
google.com [TXT] [ms=e4a68b9ab2bb9670bce15412f62916164c0b20bb]  
google.com [TXT] [google-site-verification=wd8n7iljtnkzej49swvww48f8_9xvrev4ob-0hf5o]  
google.com [TXT] [facebook-domain-verification=22rm551cu4k0ab0bxsw536tlds4h95]  
google.com [CAA] [pki.goog]
```

[dnsx](#)

IP Lookup

ASN Lookup

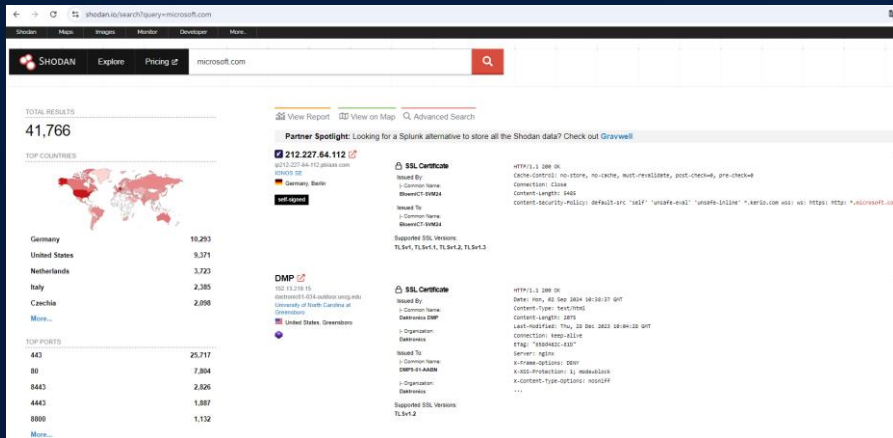
<https://bgp.he.net/>

<https://asnlookup.com/>

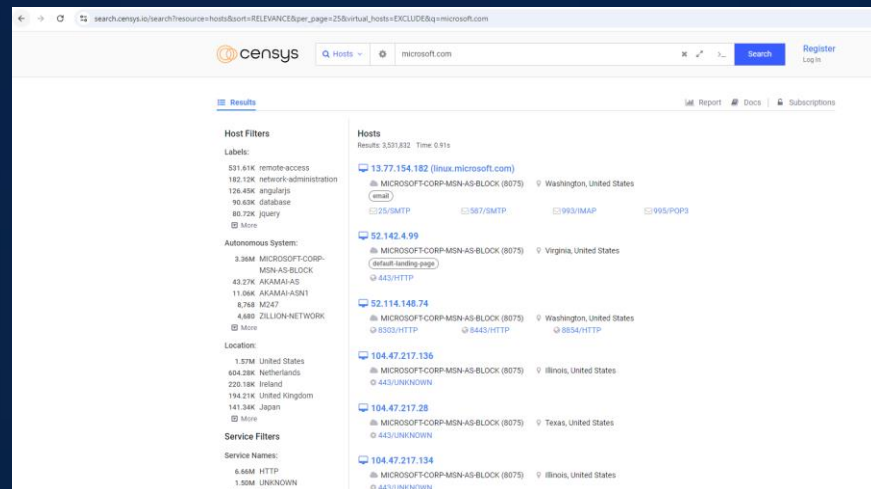
ASNmap

← → ↻ asnlookup.com/asn/AS8075				
ASNLOOKUP Internet Numbers Search Engine				
Home				
MICROSOFT-CORP-MSN-AS-BLOCK				
AS Handle	AS8075			
ASN Name	MICROSOFT-CORP-MSN-AS-BLOCK			
Organization Name	MICROSOFT-CORP-MSN-AS-BLOCK			
Organization ID	MSFT-ARIN			
Country	United States of America			
Regional Registry	ARIN			
IPv4 CIDRs	2.58.103.0/24 5.23.34.0/24 13.107.0.0/23 13.107.14.0/24 13.107.24.0/21 13.107.41.0/24 13.107.57.0/24 13.107.130.0/23 13.107.141.0/24 13.107.192.0/19 13.107.252.0/23 20.33.9.0/24 20.33.50.0/24 20.33.58.0/24 20.33.74.0/23			
	4.144.0.0/12 13.64.0.0/11 13.107.2.0/24 13.107.17.0/24 13.107.32.0/22 13.107.44.0/22 13.107.58.0/23 13.107.132.0/22 13.107.142.0/23 13.107.224.0/20 13.107.255.0/24 20.33.28.0/24 20.33.52.0/24 20.33.60.0/24 20.33.80.0/24			
	4.160.0.0/11 13.104.0.0/15 13.107.8.0/24 13.107.20.0/24 13.107.36.0/23 13.107.53.0/24 13.107.60.0/22 13.107.136.0/24 13.107.144.0/20 13.107.240.0/21 20.0.0.0/11 20.33.42.0/24 20.33.54.0/24 20.33.64.0/23 20.33.82.0/23			
	4.192.0.0/10 13.106.0.0/16 13.107.10.0/23 13.107.23.0/24 13.107.38.0/24 13.107.55.0/24 13.107.64.0/18 13.107.138.0/24 13.107.160.0/19 13.107.248.0/22 20.33.7.0/24 20.33.47.0/24 20.33.56.0/24 20.33.70.0/24 20.33.84.0/22			

Shodan - Censys

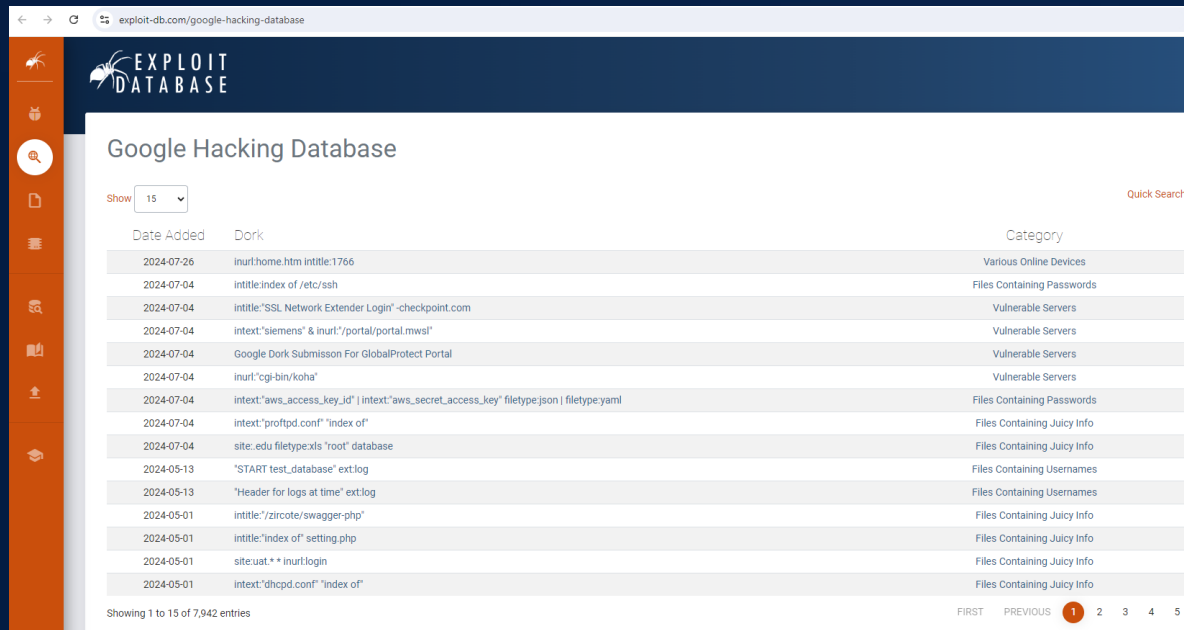


<https://www.shodan.io/>



<https://search.censys.io/>

Google Dork



exploit-db.com/google-hacking-database

Google Hacking Database

Show 15 Quick Search

Date Added	Dork	Category
2024-07-26	inurl:home.htm intitle:1766	Various Online Devices
2024-07-04	intitle:index of /etc/ssh	Files Containing Passwords
2024-07-04	intitle:"SSL Network Extender Login"-checkpoint.com	Vulnerable Servers
2024-07-04	intext:"siemens" & inurl:"portal/portal.mwsl"	Vulnerable Servers
2024-07-04	Google Dork Submission For GlobalProtect Portal	Vulnerable Servers
2024-07-04	inurl:"cgi-bin/koha"	Vulnerable Servers
2024-07-04	intext:"aws_access_key_id" intext:"aws_secret_access_key" filetype:json filetype:yaml	Files Containing Passwords
2024-07-04	intext:"proftpd.conf" "index of"	Files Containing Juicy Info
2024-07-04	site:.edu filetype:xls "root" database	Files Containing Juicy Info
2024-05-13	"START test_database" ext:log	Files Containing Usernames
2024-05-13	"Header for logs at time" ext:log	Files Containing Usernames
2024-05-01	intitle:"/zircote/swagger-php"	Files Containing Juicy Info
2024-05-01	intitle:"index of" setting.php	Files Containing Juicy Info
2024-05-01	site:uat.* inurl:login	Files Containing Juicy Info
2024-05-01	intext:"dhcpcd.conf" "index of"	Files Containing Juicy Info

Showing 1 to 15 of 7,942 entries

FIRST PREVIOUS 1 2 3 4 5

<https://www.exploit-db.com/google-hacking-database>

Subdomain Enumeration

- [Amass](#)
- [Subfinder](#)
- [Sublist3r](#)
- [Assetsfinder](#)



```
amass enum -passive -d domain.com | anew domain.txt  
subfinder -d domain.com -all -silent | anew domain.txt  
assetfinder -subs-only domain.com | anew domain.txt
```

Naabu
Masscan
Nmap

```
[WRN] Use with caution. You are responsible for your actions
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
[INF] Running SYN scan with root privileges
[INF] Found 4 ports on host hackerone.com (104.16.100.52)
```

```
hackerone.com:80
hackerone.com:443
hackerone.com:8443
hackerone.com:8080
```

```
htpx -status-code -title -tech-detect -list sub_domains.txt
```

```
    _/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/__
   /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/
  // // // // // // // // // // // // // // // // // // // // // // // // // // // // //
 /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/ /_/
// // // // // // // // // // // // // // // // // // // // // // // // // // // // //
/__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/ /__/
                                     v1.1.2

projectdiscovery.io
```

Use with caution. You are responsible for your actions.
Developers assume no liability and are not responsible for any misuse or damage.

```
https://mta-sts.hackerone.com [404] [Page not found · GitHub Pages] [GitHub Pages,Ruby on Rails]
https://mta-sts.forwarding.hackerone.com [404] [Page not found · GitHub Pages] [GitHub Pages,Ruby on Rails]
https://mta-sts.managed.hackerone.com [404] [Page not found · GitHub Pages] [GitHub Pages,Ruby on Rails]
https://api.hackerone.com [200] [HackerOne API] [Cloudflare,jsDelivr]
https://docs.hackerone.com [200] [HackerOne Platform Documentation] [Gatsby,GitHub Pages,React,Ruby on Rails,jsDelivr,webpack]
https://support.hackerone.com [301] [] [Cloudflare]
https://gslink.hackerone.com [404] [404 Not Found] [Amazon Cloudfront,Amazon Web Services,Nginx]
https://resources.hackerone.com [301] []
```

httpx

SSL/TLS

```
(pentest@kali) - [~/go/bin]  
$ ./tlsx -u www.microsoft.com -so -tls-version -cipher -hash sha256
```

```
  _____  
 |  _  _  | / _  \ V /  
 |  _  _  | \  _  > <  
 |  _  _  |  \  _ / \ \  
 |  _  _  |   \_/_/  \  v1.1.7
```

projectdiscovery.io

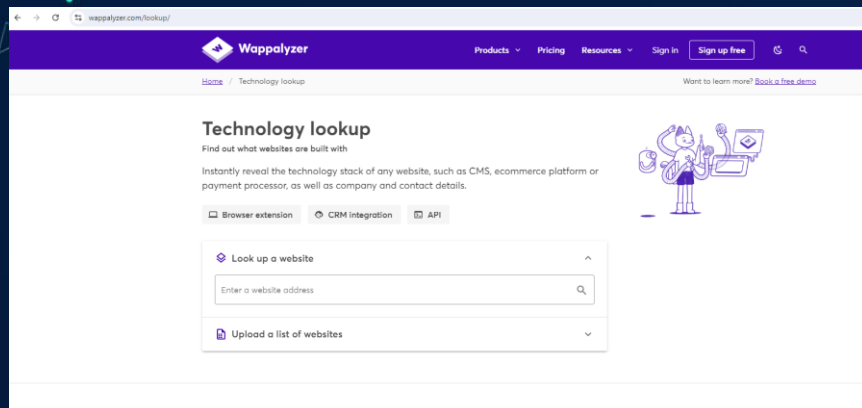
[INF] Current tlsx version v1.1.7 (latest)

www.microsoft.com:443 [Microsoft Corporation] [TLS13] [TLS_AES_256_GCM_SHA384] [5e7ee1bf7b02de6407578402e68f30e4074a4c6804dae9b7125070e26ea56bf0]

[INF] Connections made using crypto/tls: 1, zcrypto/tls: 0, openssl: 0

tlsx

Teknoloji Tespiti



<https://www.wappalyzer.com/lookup/>

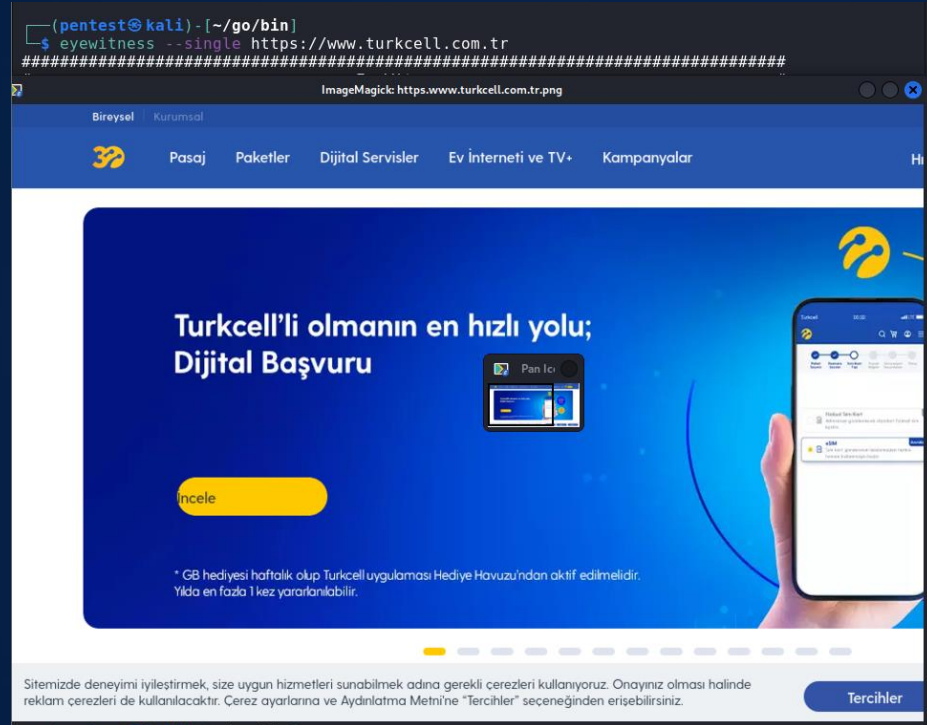
```
(pentest@kali) - [~/go/bin]
$ ./webanalyze -host https://x.com
:: webanalyze           : v0.3.9
:: workers              : 4
:: technologies         : technologies.json
:: crawl count          : 0
:: search subdomains    : true
:: follow redirects     : false

https://x.com (0.4s):
  Express, (Web frameworks, Web servers)
  Node.js, (Programming languages)
  HSTS, (Security)
  Amazon S3, (CDN)
  Amazon Web Services, (PaaS)
  Plaid, (Payment processors, Miscellaneous)
```

[webanalyze](#)

Web Screenshot

- [EyeWitness](#)
- [Webscreenshot](#)



İçerik Keşfi URL

waybackurls
gau

```
(pentest@kali) - [~/go/bin]
$ ./waybackurls https://www.yeswehack.com
http://yeswehack.com/
https://yeswehack.com/
https://yeswehack.com/de/firebounty.html
https://yeswehack.com/de/infosec-jobboard.html
https://yeswehack.com/de/mentions.html
https://yeswehack.com/de/yeswehack.html
https://yeswehack.com/en/fic-2018.html
https://yeswehack.com/en/firebounty.html
https://yeswehack.com/en/infosec-jobboard.html
https://yeswehack.com/en/mentions.html
https://yeswehack.com/en/yeswehack.html
https://yeswehack.com/es/firebounty.html
https://yeswehack.com/es/infosec-jobboard.html
https://yeswehack.com/es/mentions.html
https://yeswehack.com/es/yeswehack.html
https://yeswehack.com/fr/index.html
http://yeswehack.com/robots.txt
https://yeswehack.com/robots.txt
http://blog.yeswehack.com/
https://blog.yeswehack.com/
https://blog.yeswehack.com/2016/09/13/the-crowd-security-way/
https://blog.yeswehack.com/2017/02/07/yeswehack-is-now-member-of-fntcs-business-incubator/
https://blog.yeswehack.com/2017/09/07/confronting-reality-is-the-duty-of-every-it-security-professional/
https://blog.yeswehack.com/2017/11/06/politique-incitative-a-la-divulgation-coordonnee-de-vulnerabilites/
https://blog.yeswehack.com/2018/03/08/yeswehack-rejoint-lalliance-pour-la-confiance-numerique/
https://blog.yeswehack.com/2018/04/12/bug-bounty-franchir-le-pas-itw-dalain-tiemblo-blablacar/
https://blog.yeswehack.com/2018/04/23/bug-bounty-take-the-leap-itw-alain-tiemblo-blablacar/
```

İçerik Keşfi

Directory Fuzzing

ffuf
wfuzz

```
(root@kali) - [/opt/ffuf]  
# ./ffuf -u https://x.com/FUZZ -w /home/pentest/Desktop/wordlist/onelistforallshort.txt -ac -mc 200 -t 20
```



v1.3.1-dev

```
-----  
:: Method      : GET  
:: URL         : https://x.com/FUZZ  
:: Wordlist    : FUZZ: /home/pentest/Desktop/wordlist/onelistforallshort.txt  
:: Follow redirects : false  
:: Calibration : true  
:: Timeout     : 10  
:: Threads    : 20  
:: Matcher    : Response status: 200  
:: Filter     : Response size: 2698,2710,2678,2674  
:: Filter     : Response words: 301  
:: Filter     : Response lines: 40  
-----
```

Wordlist : <https://github.com/danielmiessler/SecLists/tree/master/Discovery/Web-Content>

```

katana -u https://tesla.com

  __
 /  \_/_/_/_/_/_/_/_/_/_/_/_/_/_/_/_
 /  '  \_/_/_/_/_/_/_/_/_/_/_/_/_/_
/_/_\_\_\_,/_/_\_\_\_,/_/_/_/_/_/_/_ v0.0.1

projectdiscovery.io

[WRN] Use with caution. You are responsible for your actions.
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
https://www.tesla.com/support/taking-delivery?redirect=no
https://www.tesla.com/shop?tesref=true
https://www.tesla.com/modules/custom/tesla_banners/js/index.js?v=1.x
https://www.tesla.com/sv_se/request-virtual-consultation?redirect=no
https://www.tesla.com/pt_PT/event/schedule-virtual-sales-consultation?redirect=no
https://shop.tesla.com/en_ae?redirect=no
https://www.tesla.com/ja_jp/shop?tesref=true
https://www.tesla.com/en_NZ/inventory/used/m3?redirect=no
https://www.tesla.com/en_nz/shop?tesref=true
https://www.tesla.com/zh_hk/event/modely-wmhotel-zhkk?redirect=no
https://www.tesla.com/en_au/shop?tesref=true
https://shop.tesla.com?tesref=true
https://www.tesla.com/de_DE/event/schedule-virtual-sales-consultation?redirect=no
https://www.tesla.com/energy/design/poi=solarroof
https://www.tesla.com/?redirect=no

```

katana

İçerik Keşfi

Javascript Enum

```
https://github.com/github/roadmap
https://resources.github.com/devops/tools/compare
https://docs.github.com/get-started/exploring-integrations/about-building-integrations
https://github.com/edu
https://cli.github.com
https://desktop.github.com
https://github.com/mobile
https://github.community
https://services.github.com
/enterprise/premium-support
https://www.githubstatus.com
https://support.github.com?tags=dotcom-footer
https://github.com/about
/customer-stories?type=enterprise
/readme
https://github.careers
/about/press
/about/diversity
https://socialimpact.github.com
https://shop.github.com
https://docs.github.com/site-policy/github-terms/github-terms-of-service
https://docs.github.com/site-policy/privacy-policies/github-privacy-statement
https://github.com/github/site-policy/pull/582
/sitemap
/git-guides
https://x.com/github
https://www.facebook.com/GitHub
https://www.linkedin.com/company/github
https://www.youtube.com/github
https://www.twitch.tv/github
https://www.tiktok.com/@github
https://github.com/github

(pentest@kali) - [~/go/bin]
$ ./GoLinkFinder -d https://github.com | grep api
https://api.github.com/_private/browser/stats
https://api.github.com/_private/browser/errors
```

Golinkfinder

minamo7sen/burp- JS-Miner



This tool tries to find interesting stuff inside static files; mainly JavaScript and JSON files.

2

Contributors

0

Issues

45

Stars

16

Forks



JS Miner

İçerik Keşfi Parametre

```
(pentest@kali) - [~/go/bin]  
$ arjun -u https://microsoft.com
```

```
  _/ _| _| _|  
( _| _| _| _| v2.2.6  
  _/
```

```
[*] Probing the target for stability  
[*] Analysing HTTP response for anomalies  
[*] Analysing HTTP response for potential parameter names  
[+] Heuristic scanner found 1 parameter: cli_shellHeaderSearchInput  
[*] Logicforcing the URL endpoint  
[✓] parameter detected: t, based on: http code  
[+] Parameters found: t
```

Tarama Araçları

- [Nuclei](#) - template bazlı tarama aracı
- [Commix](#) - command injection exploitation aracı
- [SQLMap](#), [Ghauri](#) - SQLi exploitation aracı
- [WPScan](#) - WordPress scanner
- [Droopescan](#) - Drupal, CMS scanner
- [DalFox](#) - XSS scanner
- [Retire.js](#) - Detect the use of JS-library versions with known vulnerabilities
- [reNgin](#) - Automated Reconnaissance Framework



Diğer

- [Anew](#)
- [Notify](#)
- [Intertachsh](#)
- Payload Lists
- [Wordlists](#)

